

Yellow RAT Lab

Analyze malware artifacts using threat intelligence platforms like VirusTotal to identify IOCs, C2 servers, and understand adversary tactics.

Category:

- Threat Intel

Tools:

- VirusTotal
- Red Canary

Scenario:

Durante una verificación de seguridad de TI regular en GlobalTech Industries, se detectó tráfico de red anormal desde múltiples estaciones de trabajo. Tras la investigación inicial, se descubrió que las consultas de búsqueda de ciertos empleados estaban siendo redirigidos a sitios web desconocidos. Este descubrimiento generó preocupaciones y provocó una investigación más exhaustiva. Su tarea es investigar este incidente y recopilar la mayor cantidad de información posible.

malware hash:

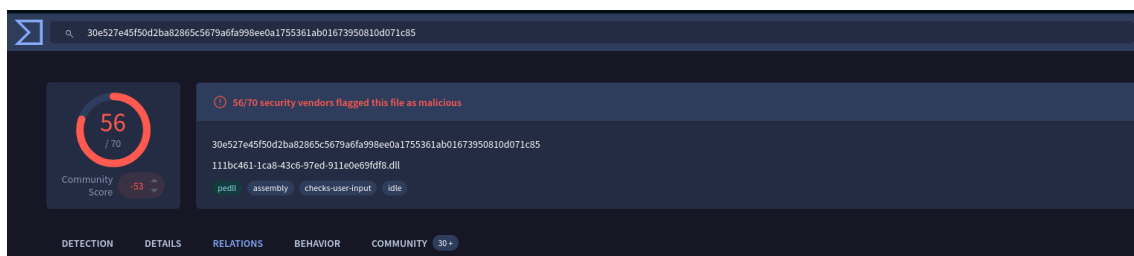
30E527E45F50D2BA82865C5679A6FA998EE0A1755361AB01673950810D071C85

Use this hash on online threat intel platforms (e.g., VirusTotal, Hybrid Analysis) to complete the lab analysis.

Pregunta 01:

Entender al adversario ayuda a defenderse de los ataques. ¿Cuál es el nombre de la familia de malware que causa el tráfico de red anormal?

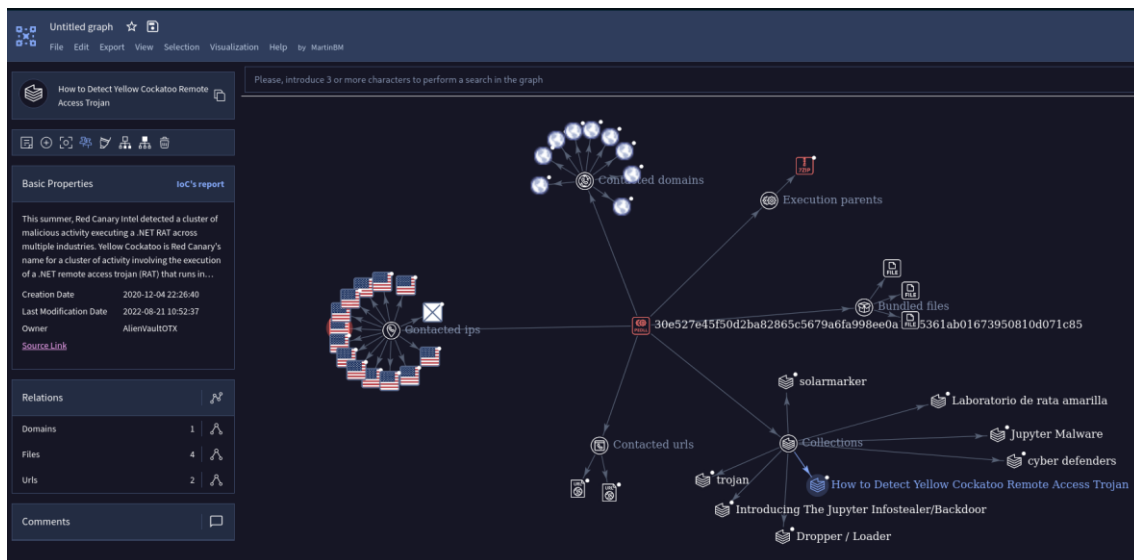
Subimos el hash a VirusTotal y vamos a la sección de “Relations”:



Navegamos hasta el fondo y vamos a “Graph Summary”:



Damos clic al icono central del grafo.



Las “Collections” son conjuntos de muestras analizadas por investigadores de VirusTotal o de la comunidad. Si una muestra pertenece a una campaña o familia conocida, normalmente la colección lo indica.

En la captura se ven varias colecciones relacionadas:

- solarmarker
- Introducing The Jupyter Infostealer/Backdoor
- Dropper / Loader
- How to Detect Yellow Cockatoo Remote Access Trojan
- Laboratorio de rata amarilla
- Jupyter Malware

La colección “How to Detect Yellow Cockatoo Remote Access Trojan” describe una campaña del “Yellow Cockatoo RAT”. Al abrirla, el artículo menciona lo siguiente:

DETECTION	DETAILS	RELATIONS	BEHAVIOR	COMMUNITY
30+				
Basic properties				
MDS	4eb6170524b5e18d95b5b56b937e89b36			
SHA-1	f76e293d627c55eca18ce96e587b8c6e37d8206			
SHA-256	30e527e45f50d2ba2865c5679afaf98ee0a1755361ab01673950810d071c85			
Vhash	36403665151b002c3002b1			
Authentichash	67299064416344fcd2890b9ca06f83d7fbd7334e44528cded73206ce57			
Impshash	dae02f32a1e03ce65412f6e56942daa			
SSDEEP	768:RuedT7-DWtOWpky00EuA0bR0BL8gDUJBMZ7wdZ7TmkaZi9nh:RU0sC0aEuA0bX0BAGeZ7wduWHn1			
TLSH	T15963A54D3AF60596CDECBFC70443D5169B34E452D3835B2D1FE99B622AAT0284CE08F			
File type	Win32 DLL (console) Intel 80386 Mono/.Net assembly, for MS Windows			
Magic	PE32 executable (DLL) (console) Intel 80386 Mono/.Net assembly, for MS Windows			
TrID	Win32 Dynamic Link Library (generic) (20%) Win64 Executable (generic) (19.8%) Win16 NE executable (generic) (15.3%) Win32 Executable (generic) (13.7%) Win16/32 Executable Delphi generic (6.3%)			
DetectItEasy	PE32 Library: .NET (v2.0.50727) Linker: Microsoft Linker (8.0)			
Magika	PEBIN			
File size	68.00 KB (69632 bytes)			
PEID packer	.NET executable			
History				
Creation Time	2020-09-24 18:26:47 UTC			
First Seen In The Wild	2021-01-18 20:15:04 UTC			
First Submission	2020-10-15 02:47:37 UTC			
Last Submission	2020-05-01 16:46:44 UTC			
Last Analysis	2026-07-24 18:34:04 UTC			

Respuesta: 2020-09-24 18:26

Pregunta 04:

Entender cuándo la comunidad de ciberseguridad en general identificó por primera vez que el malware podría ayudar a determinar cuánto tiempo podría haber estado el malware en el entorno antes de la detección. ¿Cuándo se envió el malware por primera vez a VirusTotal?

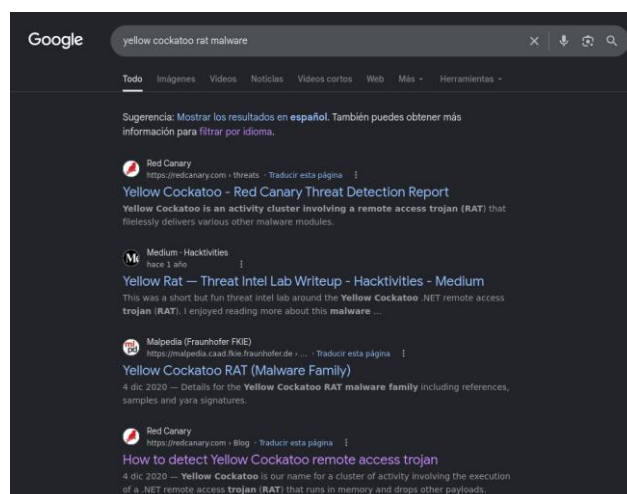
Esta pregunta se resuelve con la captura anterior, solo que la fecha que nos importa es la de “First Submission”.

Respuesta: 2020-10-15 02:47

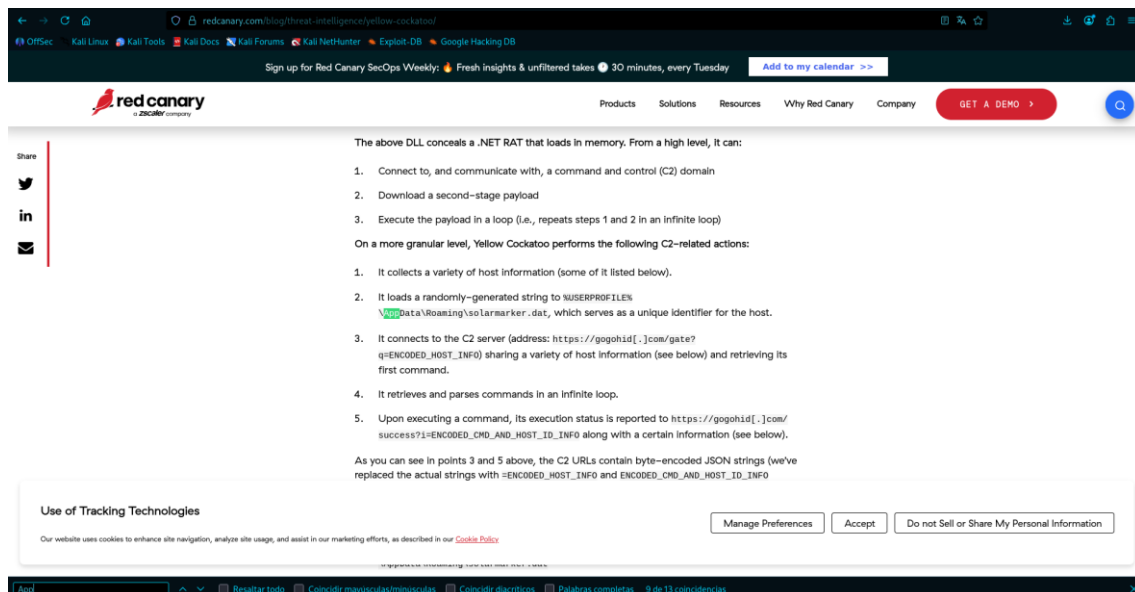
Pregunta 05:

Para erradicar completamente la amenaza de los sistemas de Industries, necesitamos identificar todos los componentes abandonados por el malware. ¿Cuál es el nombre del archivo .dat que el malware dejó caer en la carpeta AppData?

Buscamos en internet este caso y buscamos entre las páginas que nos salen para buscar información.



Si entramos a la cuarta opción encontraremos la información que nos piden. Nos ayudamos con Ctrl + F buscando con palabras de ayuda para tener una búsqueda mas rápida.



The above DLL conceals a .NET RAT that loads in memory. From a high level, it can:

1. Connect to, and communicate with, a command and control (C2) domain
2. Download a second-stage payload
3. Execute the payload in a loop (i.e., repeats steps 1 and 2 in an infinite loop)

On a more granular level, Yellow Cockatoo performs the following C2-related actions:

1. It collects a variety of host information (some of it listed below).
2. It loads a randomly-generated string to %USERPROFILE%\AppData\Roaming\solarmarker.dat, which serves as a unique identifier for the host.
3. It connects to the C2 server (address: https://gogohid[.]com/gate?q=ENCODED_HOST_INFO) sharing a variety of host information (see below) and retrieving its first command.
4. It retrieves and parses commands in an infinite loop.
5. Upon executing a command, its execution status is reported to https://gogohid[.]com/success?l=ENCODED_CMD_AND_HOST_ID_INFO along with a certain information (see below).

As you can see in points 3 and 5 above, the C2 URLs contain byte-encoded JSON strings (we've replaced the actual strings with ENCODED_HOST_INFO and ENCODED_CMD_AND_HOST_ID_INFO)

Use of Tracking Technologies

Our website uses cookies to enhance site navigation, analyze site usage, and assist in our marketing efforts, as described in our [Cookie Policy](#)

Manage Preferences Accept Do not Sell or Share My Personal Information

Find

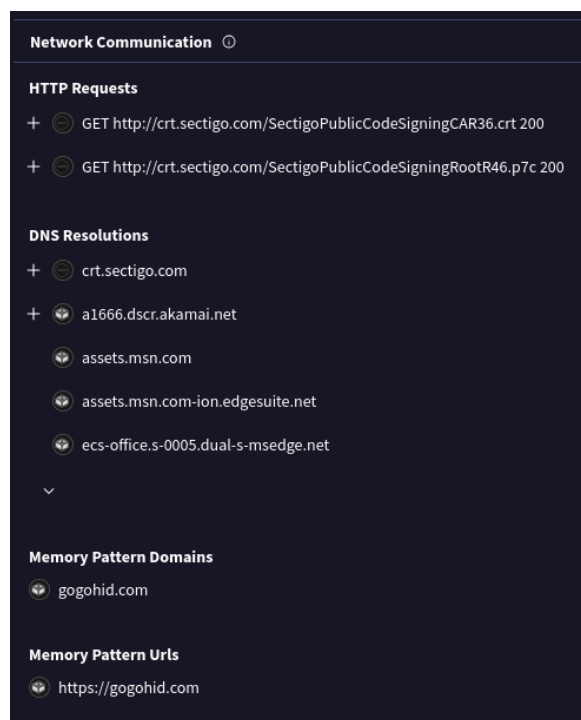
Regular todo Conceder mayor privacidad Conceder privacidad Conceder privacidad 9 de 13 coincidencias

Respuesta: solarmarker.dat

Pregunta 06:

Es crucial identificar los servidores C2 con los que el malware se comunica para bloquear su comunicación y evitar una mayor exfiltración de datos. ¿Qué es el servidor C2 con el que se comunica el malware?

Vamos a la sección de “Behavior” y vamos a la parte de “Network Communication”.



Network Communication

HTTP Requests

- + GET http://crt.sectigo.com/SectigoPublicCodeSigningCAR36.crt 200
- + GET http://crt.sectigo.com/SectigoPublicCodeSigningRootR46.p7c 200

DNS Resolutions

- + crt.sectigo.com
- + a1666.dscr.akamai.net
- + assets.msn.com
- + assets.msn.com-ion.edgesuite.net
- + ecs-office.s-0005.dual-s-msedge.net

Memory Pattern Domains

- + gogohid.com

Memory Pattern Urls

- + https://gogohid.com

Aquí, encontrarás el Memory Pattern URLs. Lo que revela el servidor C2 con el que se comunica el malware.

Respuesta: <https://gogohid.com>

FIN DEL LABORATORIO